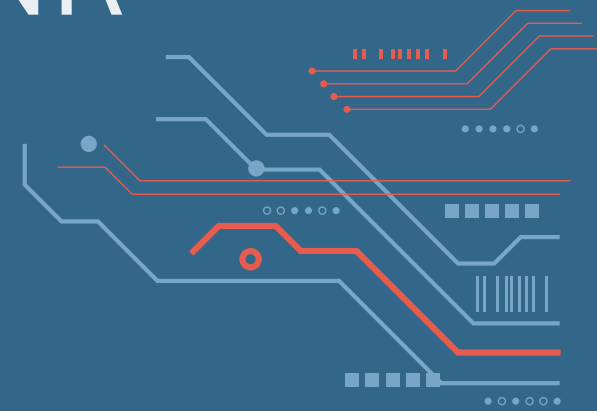


INTRODUCCIÓN A LAS APIs TUIA | FCEIA UNR

Docentes | 1C 2025

Esteban Toribio
Iván Pellejero
Juan Pablo Michelino
Renzo Mare
Tomas Ubaldi

toribio@fceia.unr.edu.ar
ipellejero@fceia.unr.edu.ar
jpmich@fceia.unr.edu.ar
rmare@fceia.unr.edu.ar
tomasubaldi@fceia.unr.edu.ar



10

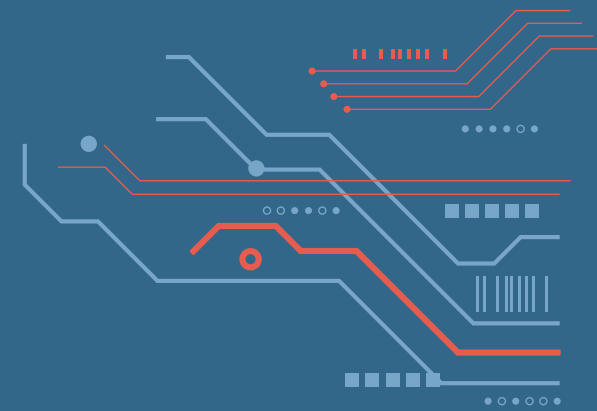


REST APIs

- 10.1. Introducción a REST API
- 10.2. Trabajo con Webhooks
- 10.3. Autenticación de REST API
- 10.4. Límite de velocidad de las APIs



INTRODUCCIÓN A REST API



Solicitud, respuesta y diagrama de
secuencia.

REST API Web Service

- Una API de servicio web REST (API REST) es una interfaz de programación que se comunica a través de HTTP.
- Las REST API utilizan los mismos conceptos que el protocolo HTTP que son los siguientes:
 - Solicitudes/respuestas HTTP
 - Verbos HTTP
 - Código de estado HTTP
 - Encabezados/cuerpo HTTP



Solicitudes de API REST

- Las solicitudes de REST API son solicitudes HTTP que son una forma de que una aplicación (cliente) pida al servidor que realice una función.
- Las solicitudes de REST API se componen de cuatro componentes principales:
 - Identificador uniforme de recursos (URI)
 - Método HTTP:
 - Encabezado
 - Cuerpo

Solicitudes de REST API

El Universal Resource Identifier (URI), también conocido como Universal Resource Locator (URL), identifica qué recurso desea manipular el cliente.

Los componentes de un URI son:

- **Esquema:** Especifica qué protocolo se debe usar (http o https)
- **Autoridad:** Consta de dos partes, a saber, host y puerto.
- **Ruta de acceso:** Representa la ubicación del recurso, los datos u objeto, que se va a manipular en el servidor.
- **Consulta:** Proporciona detalles adicionales sobre el ámbito, el filtrado o para aclarar una solicitud.



Solicitudes de REST API

Método HTTP:

- Las REST API utilizan los métodos HTTP estándar para comunicarse con los servicios web.

Método HTTP:	Acción	Descripción
POST	Crear (<u>Create</u>)	Crear un nuevo objeto o recurso.
GET	lectura (Read)	Recuperar detalles de recursos del sistema.
PUT	Actualizar	Reemplace o actualice un recurso existente.
PARCHE	Actualización parcial	Actualice algunos detalles de un recurso existente.
DELETE	Eliminar (Delete)	Remover un recurso del sistema.

Solicitudes de REST API

Encabezado:

Los encabezados HTTP tienen el formato de pares nombre-valor separados por dos puntos (:), [nombre]: [valor].

Dos tipos de encabezados:

- **Encabezados de solicitud:** Incluye información adicional que no esté relacionada con el contenido del mensaje.

Clave	Valor de ejemplo	Descripción
Autorización	DMFNCFUDDP2YWDYYW básico	Proporciona credenciales para autorizar la solicitud

- **Encabezados de entidad:** Información adicional que describe el contenido del cuerpo del mensaje.

Clave	Valor de ejemplo	Descripción
Tipo de contenido	aplicación/ JSON	Especificar el formato de los datos en el cuerpo

Solicitudes de REST API

Cuerpo:

- El cuerpo de la solicitud de REST API contiene los datos correspondientes al recurso que el cliente desee manipular.
- Las solicitudes de REST API que utilizan el método HTTP POST, PUT y PATCH suelen incluir un cuerpo.
- El cuerpo es opcional dependiendo del método HTTP.
- Si los datos se proporcionan en el cuerpo, entonces el tipo de datos debe especificarse en el encabezado mediante la clave de Content-Type.

Respuestas REST API

- Las respuestas de la REST API son respuestas HTTP que comunican los resultados de la solicitud HTTP de un cliente.
- Respuesta REST API se componen de tres componentes principales:
 - Estado HTTP
 - Encabezado
 - Cuerpo

Respuestas REST API

Estado HTTP

- El código de estado HTTP ayuda al cliente a determinar el motivo del error y puede proporcionar sugerencias para solucionar el problema.
- Los códigos de estado HTTP constan de tres dígitos, donde el primer dígito es la categoría de respuesta y los otros dos dígitos son asignados en orden numérico:
 - **Informativo (1xx):** Con fines informativos, las respuestas no contienen un cuerpo.
 - **Éxito (2xx):** El servidor recibió y ha aceptado la solicitud.
 - **Redirección (3xx):** El cliente tiene que tomar una acción adicional para completar la solicitud.
 - **Error de cliente (4xx):** La solicitud contiene un error como sintaxis incorrecta o entrada no válida.
 - **Error del servidor (5xx):** No se pueden cumplir las solicitudes válidas.

Respuestas REST API

Los códigos de estado HTTP comunes son los siguientes:

Código de Estado HTTP	Mensaje de estado	Descripción
200	Aceptar	La solicitud se realizó correctamente y normalmente contiene una carga útil (cuerpo)
201	Creada	Se cumplió la solicitud y se creó el recurso que fue solicitado
202	Aceptada	La solicitud ha sido aceptada para su procesamiento y está en proceso
400	Solicitud no válida	La solicitud no se procesará debido a un error con la solicitud
401	No autorizado	La solicitud no tiene credenciales de autenticación válidas para realizar la solicitud
403	Prohibida	La solicitud ha sido entendida pero ha sido rechazada por el servidor
404	No se encontró	No se puede cumplir la solicitud porque la ruta de acceso del recurso de la solicitud no se encontró en el servidor
500	Error del servidor interno	No se puede cumplir la solicitud debido a un error del servidor
503	El servicio no está disponible	No se puede cumplir la solicitud porque actualmente el servidor no puede manejar la solicitud

Respuestas REST API

Encabezado: La respuesta proporciona información adicional entre el servidor y el cliente en el formato de par nombre-valor que está separado por dos puntos (:), [nombre]: [valor]. Hay dos tipos de encabezados:

- **Encabezados de respuesta:** Contiene información adicional que no está relacionada con el contenido del mensaje. Los encabezados de respuesta típicos para una solicitud de API REST incluyen:

Clave	Valor de ejemplo	Descripción
Set-Cookie	JSESSIONID=30A9DN810FQ428P; Ruta=/ 	Se utiliza para enviar Cookies desde el servidor
Control de caché	Control de caché: max-edad=3600, público	Especificar directivas que DEBEN ser obedecidas por todos los mecanismos de almacenamiento en el caché

- **Encabezados de entidad:** Son información adicional que describe el contenido del cuerpo del mensaje. Un encabezado de entidad común especifica el tipo de datos que son devueltos:

Clave	Valor de ejemplo	Descripción
Tipo de contenido	Aplicación/JSON	Especificar el formato de los datos en el cuerpo

Respuestas REST API

Paginación de respuestas

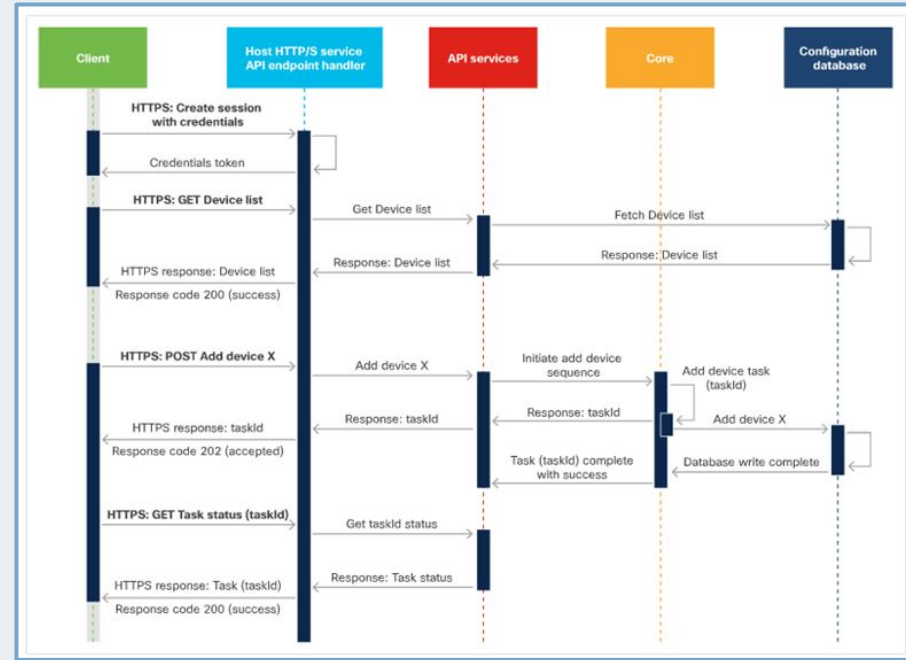
- La paginación de respuestas permite dividir los datos en fragmentos.
- La mayoría de las API utilizan el parámetro de consulta para especificar qué página devolver en la respuesta.

Datos de respuesta comprimidos

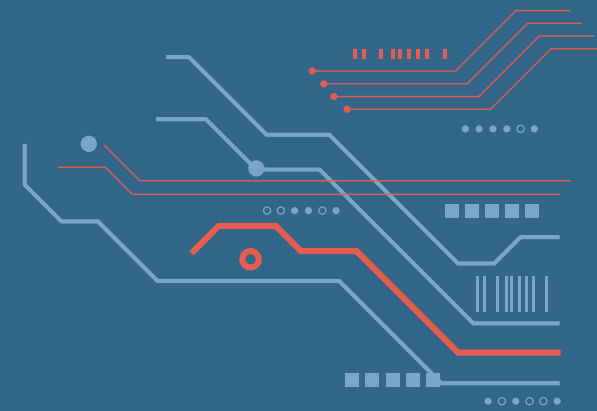
- Los datos comprimidos reducen la gran cantidad de datos que no se pueden paginar.
- Para solicitar una compresión de datos, la solicitud debe agregar el campo Accept-Encoding al encabezado de solicitud. Los valores aceptados son:
 - gzip
 - Comprimir
 - desinflar
 - br
 - identidad
 - *

Diagramas de secuencia de REST API

- Los diagramas de secuencia se utilizan para explicar una secuencia de intercambios o eventos.
- El diagrama de secuencia de solicitud de API tiene tres secuencias separadas:
 - **Crear sesión:** La solicitud de inicio se etiqueta como HTTPS.
 - **Obtener dispositivos:** Solicite una lista de dispositivos de la plataforma.
 - **Crear dispositivo:** Empieza con una solicitud POST para crear un dispositivo.



TRABAJO CON WEBHOOKS



¿Que es una webhook? Y Construir una
Webhook

¿Qué es un WebHook?

- Un Webhook es una devolución de llamada HTTP, o un HTTP POST, a una URL especificada que notifica a la aplicación cuando se produce una actividad o evento en particular en los recursos.
- Con WebHooks, las aplicaciones son más eficientes ya que no se requieren mecanismos de sondeo.
- Los webhooks también se conocen como API inversas, porque las aplicaciones se suscriben a un servidor WebHook.
- Varias aplicaciones pueden suscribirse a un único servidor WebHook.

¿Qué es un WebHook?

Ejemplos:

- La plataforma Cisco DNA Center proporciona WebHooks que permiten a las aplicaciones de terceros recibir datos de red cuando se producen eventos especificados.
- Puede crear un WebHook para que Cisco Webex Teams le notifique de nuevos mensajes publicados en una sala en particular.

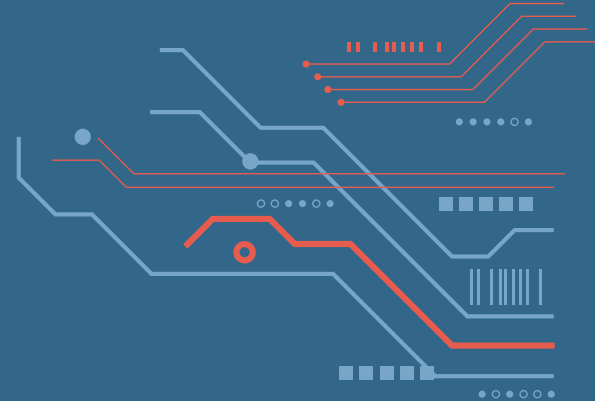
Construir un WebHook

- Para recibir una notificación de un proveedor de WebHook, la aplicación debe cumplir ciertos requisitos:
 - La aplicación debe ejecutarse en todo momento para recibir solicitudes HTTP POST.
 - La aplicación debe registrar un URI en el proveedor WebHook.
- La aplicación debe manejar las notificaciones entrantes del servidor WebHook.

AUTENTICACIÓN A LA REST API



Autenticación, autenticación vs
autorización y mecanismos de
autenticación.



Autenticación de REST API

- Las REST API requieren autenticación para que los usuarios aleatorios no puedan acceder, crear, actualizar o eliminar información de forma incorrecta o maliciosa.
- Algunas API que no requieren autenticación son de sólo lectura y no contienen información crítica o confidencial.

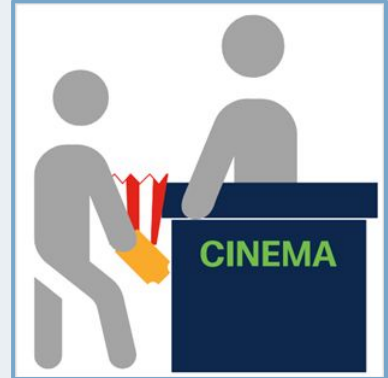
Autenticación vs Autorización

Autenticación: La autenticación demuestra la identidad del usuario.

Por ejemplo, cuando vas al aeropuerto y muestras tu identificación emitida por el gobierno o usar biometría para demostrar que eres la persona que afirmas ser.

Autorización: La autorización define el acceso al usuario. Es el acto en el que el usuario está demostrando tener permisos para realizar la acción solicitada en ese recurso.

Por ejemplo, cuando vas a un concierto solo necesitas mostrar tu ticket para demostrar que estás permitido entrar.



Mecanismos de autenticación

Los tipos comunes de mecanismos de autenticación incluyen:

- **Autenticación básica:** Transmite credenciales como pares de nombre de usuario/contraseña separados con dos puntos (:) y codificados usando Base64.
- **Autenticación al portador:** Utiliza un token al portador, que es una cadena generada por un servidor de autenticación como un servicio de identidad (ID).
- **Clave API:** Es una cadena alfanumérica única generada por el servidor y asignada a un usuario. Los dos tipos de claves API son públicas y privadas.

Mecanismos de autenticación

La autorización abierta (OAuth) combina la autenticación con la autorización.

- Fue desarrollado como una solución para mecanismos de autenticación inseguros.
- Ha aumentado la seguridad en comparación con otras opciones.
- Hay dos versiones de OAuth: OAuth 1.0 y OAuth 2.0, donde OAuth 2.0 no es compatible con versiones anteriores.
- El marco de autorización de OAuth 2.0 permite que una aplicación de terceros obtenga acceso limitado a un servicio HTTP.
- OAuth permite al usuario proporcionar credenciales directamente al servidor de autorización [Identity Provider (IdP) o a Identity Service (ID)], para obtener un token de acceso para compartir con la aplicación.
- El proceso de obtención del token se denomina flujo.

LÍMITES DE VELOCIDAD

¿Que son los límites de velocidad?,
algoritmos de control de velocidad,
conocer el límite de velocidad y
excediendo el límite de velocidad

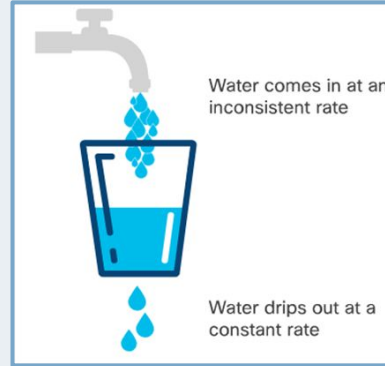
¿Qué son los límites de velocidad?

- Es una forma de que un servicio web controle el número de solicitudes que un usuario o una aplicación puede realizar por unidad de tiempo definida.
- La limitación de velocidad ayuda a:
 - Evitar una sobrecarga del servidor por demasiadas solicitudes a la vez.
 - Proporcionar un mejor servicio y tiempo de respuesta a todos los usuarios.
 - Protege en contra de un ataque de Deny of Service (DoS)

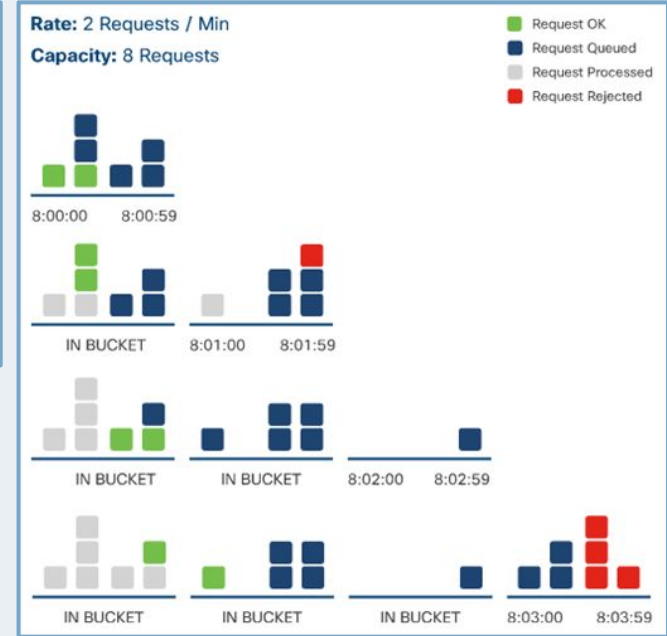
Algoritmos de límite de velocidad

Contador dinámico

- Este algoritmo pone todas las solicitudes entrantes en una cola en el orden en que se recibieron.
- Las solicitudes entrantes pueden entrar en cualquier caso, pero el servidor las procesa a una tasa fija.
- Si la cola de solicitudes está llena, las nuevas solicitudes son rechazadas



Representación visual del algoritmo de balde con fugas

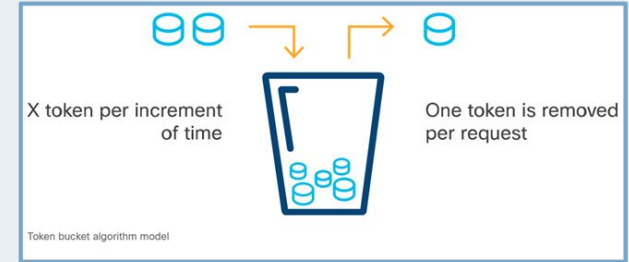


Ejemplo de algoritmo de balde con fugas.

Algoritmos de límite de velocidad

Depósito de Token

- Este algoritmo proporciona a cada usuario un número definido de tokens que pueden usar dentro de un cierto incremento de tiempo.
- Cuando el cliente realiza una solicitud, el servidor comprueba el depósito para asegurarse que contiene al menos un token. Si es así, elimina ese token y procesa la solicitud, de lo contrario la rechaza.
- El cliente debe calcular el número de tokens que tiene para evitar solicitudes rechazadas.



Modelo de algoritmo de depósito de tokens

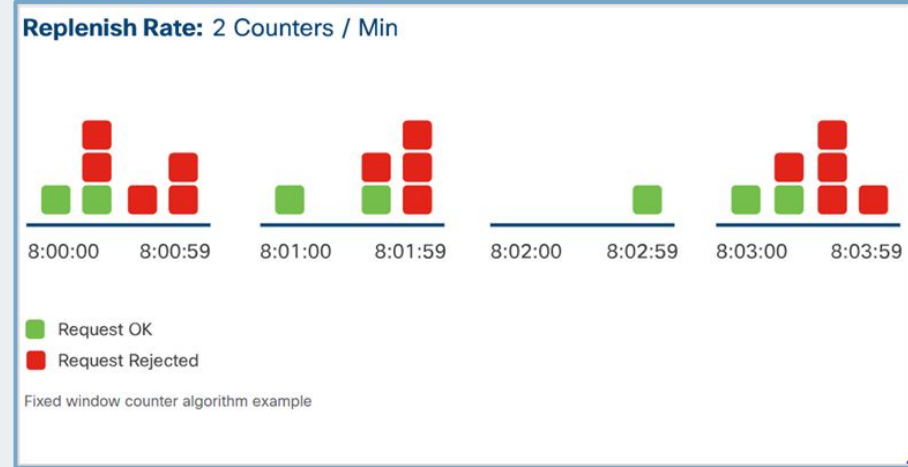


Ejemplo del algoritmo de depósito de token

Algoritmos de límite de velocidad

Contador de ventanas fijas

- A una ventana fija de tiempo se le asigna un contador de solicitudes que pueden procesar durante ese período.
- Cuando el servidor recibe una solicitud, el contador actual debe ser cero.
- Cuando se procesa la solicitud, se deduce el contador. Si se cumple el límite para ese período de tiempo, todas las solicitudes posteriores dentro de ese período de tiempo serán rechazadas.



Ejemplo de algoritmo de contador de ventana fija

Algoritmos de límite de velocidad

Contador de ventanas deslizantes

- Este algoritmo permite realizar un número fijo de solicitudes en una duración determinada de tiempo.
- Cuando se realiza una nueva solicitud, el servidor cuenta cuántas solicitudes ya se han realizado desde el principio de la ventana hasta la hora actual.
- El cliente debe asegurarse de que el límite no se exceda en el momento de la solicitud.



Ejemplo de algoritmo de contador de ventana deslizante

Conocer el límite de velocidad

- Muchas APIs agregan detalles sobre el límite de velocidad en el encabezado de la respuesta.
- Las claves de límite de velocidad comúnmente utilizadas incluyen:
 - **Límite de velocidad X:** El número máximo de solicitudes que se pueden realizar en una unidad de tiempo especificada.
 - **Límite de tasa X restante:** El número de solicitudes pendientes que el solicitante puede realizar en la ventana de límite de tasa actual
 - **X-Rate Limit-Reset:** La hora en que se restablecerá la ventana de límite de velocidad.

Excediendo el límite de velocidad

- Cuando se supera el límite de velocidad, el servidor rechaza automáticamente la solicitud y devuelve una respuesta HTTP.
- La respuesta que contiene el error también incluye un código de estado HTTP significativo.
- Los códigos de estado HTTP más utilizados son

`429: Demasiadas solicitudes` o `403: Prohibido`.